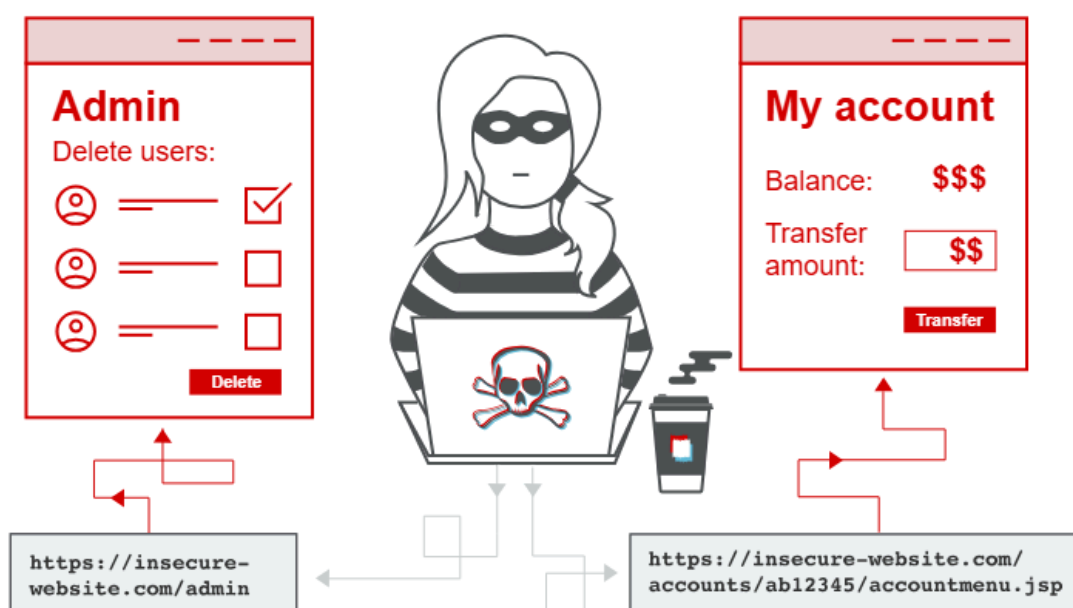


Access Control Vulnerabilities

1. Khái niệm về Kiểm soát Truy cập (Access Control):

Kiểm soát truy cập đảm bảo người dùng không thể thực hiện các hành động ngoài quyền hạn của họ. Các lỗ hổng kiểm soát truy cập như **escalation đặc quyền** (thăng cấp quyền) và **IDOR** (Insecure Direct Object References) xuất hiện khi người dùng có thể truy cập tài nguyên hoặc thực hiện hành động mà họ không được phép.

2. Thăng cấp quyền dọc và ngang (Vertical/Horizontal Privilege Escalation)



2.1. Thăng cấp quyền dọc (Vertical Privilege Escalation)

Mục tiêu: Tấn công này cho phép kẻ tấn công có quyền truy cập vào chức năng mà họ không được phép, thường là chức năng quản trị. Ví dụ, người dùng bình thường có thể truy cập trang admin.

Các bước tấn công:



1. **Phát hiện URL quản trị:** Sử dụng các công cụ brute force hoặc tìm kiếm URL ẩn như `https://website.com/admin`.
2. **Truy cập trái phép:** Truy cập trang admin bằng cách thay đổi đường dẫn URL hoặc thông qua tham số URL.
3. **Tấn công:** Nếu không có xác thực mạnh, kẻ tấn công có thể sử dụng trang này để thực hiện các hành động quản trị như xóa người dùng, thay đổi quyền, hoặc xem dữ liệu nhạy cảm.

Ví dụ:

- **URL brute-forcing:** Một trang web có URL quản trị là `https://example.com/admin-panel`. Kẻ tấn công thử các URL dựa trên dự đoán như `https://example.com/admin`, `https://example.com/manage`, cho đến khi tìm thấy trang quản trị không được bảo vệ.
- **Sử dụng API không có bảo mật:** Kẻ tấn công phát hiện API quản trị không có xác thực, ví dụ như API POST `/admin/deleteUser`, có thể xóa người dùng mà không cần quyền quản trị.

2.2. Thăng cấp quyền ngang (Horizontal Privilege Escalation)

Mục tiêu: Thăng cấp quyền ngang xảy ra khi kẻ tấn công có thể truy cập tài nguyên hoặc thông tin của người dùng khác mà không được phép.

Các bước tấn công:

1. **Xác định tham số người dùng:** Kẻ tấn công nhận ra tham số URL dùng để chỉ định người dùng (ví dụ: `id=123` trong URL).
2. **Thay đổi tham số:** Kẻ tấn công thay đổi giá trị tham số đó để thử truy cập tài khoản khác (ví dụ: `id=124`).
3. **Truy cập trái phép:** Nếu hệ thống không kiểm tra đúng quyền sở hữu, kẻ tấn công có thể truy cập tài nguyên của người dùng khác.

Ví dụ:



- **IDOR (Insecure Direct Object Reference):** Một trang web ngân hàng cho phép người dùng truy cập lịch sử giao dịch của họ qua URL `https://bank.com/myaccount?id=123`. Kẻ tấn công thay đổi tham số `id=123` thành `id=124` và có thể xem thông tin tài khoản của người dùng khác.

2.3. Kết hợp thăng cấp quyền ngang và dọc

Trong nhiều trường hợp, thăng cấp quyền ngang có thể dẫn đến thăng cấp quyền dọc khi kẻ tấn công nhắm vào tài khoản quản trị. Sau khi truy cập tài khoản của admin, họ có thể thực hiện các hành động cấp cao như xóa dữ liệu, thay đổi cấu hình hệ thống hoặc thêm quyền cho chính họ.

Ví dụ:

Kẻ tấn công thay đổi tham số `id` để truy cập tài khoản admin và sau đó lợi dụng tính năng cho phép admin thay đổi mật khẩu để chiếm quyền kiểm soát tài khoản.

3. Phương pháp tấn công cụ thể vào các lỗ hổng kiểm soát truy cập

3.1. Insecure Direct Object References (IDOR)

Tham chiếu đối tượng trực tiếp không an toàn là một phân loại con của các lỗ hổng kiểm soát truy cập. IDOR xảy ra khi một ứng dụng sử dụng đầu vào do người dùng cung cấp để truy cập trực tiếp vào các đối tượng, và kẻ tấn công có thể sửa đổi đầu vào để có được quyền truy cập trái phép. Lỗ hổng này đã trở nên phổ biến sau khi xuất hiện trong danh sách OWASP Top Ten năm 2007. Đây chỉ là một ví dụ trong nhiều lỗi triển khai có thể cung cấp phương tiện để vượt qua các kiểm soát truy cập.

Mục tiêu: Lợi dụng việc sử dụng tham số trực tiếp (ID, số thứ tự, v.v.) trong URL hoặc biểu mẫu để truy cập trái phép.

Các bước tấn công:



1. **Phân tích URL:** Kẻ tấn công nhận thấy rằng thông tin quan trọng của người dùng (ID) được bao gồm trong URL hoặc POST request.
2. **Sửa đổi tham số:** Họ thay đổi giá trị của tham số này để truy cập dữ liệu của người khác.
3. **Khai thác:** Nếu không có xác minh quyền truy cập, họ có thể xem, chỉnh sửa hoặc xóa tài nguyên của người khác.

Ví dụ:

Trong một hệ thống quản lý học sinh, giáo viên có quyền truy cập thông tin cá nhân của học sinh qua đường dẫn <https://school.com/student?id=1001>. Một giáo viên có thể thay đổi id=1001 thành id=1002 và truy cập thông tin của học sinh khác.

3.2. Bỏ qua nhiều bước kiểm soát truy cập

Nhiều trang web thực hiện các chức năng quan trọng qua một chuỗi các bước. Điều này thường gặp khi:

- Cần thu thập nhiều đầu vào hoặc tùy chọn.
- Người dùng cần xem xét và xác nhận chi tiết trước khi hành động được thực hiện.

Đôi khi, một trang web sẽ thực hiện kiểm soát truy cập nghiêm ngặt đối với một số bước trong quy trình này nhưng bỏ qua các bước khác. Hãy tưởng tượng một trang web có kiểm soát truy cập đúng cách trong các bước 1 và 2, nhưng không ở bước 3. Trang web cho rằng người dùng chỉ có thể đến bước 3 nếu họ đã hoàn thành các bước trước đó, vốn đã được kiểm soát chặt chẽ. Kẻ tấn công có thể bỏ qua hai bước đầu và trực tiếp gửi yêu cầu ở bước 3 với các tham số cần thiết để có được quyền truy cập trái phép vào chức năng này.

Mục tiêu: Tấn công lợi dụng việc kiểm soát truy cập không được triển khai đúng cách trong các bước liên tiếp của quá trình thực hiện một hành động.

Các bước tấn công:



1. **Phân tích quy trình nhiều bước:** Kẻ tấn công xác định rằng quy trình bao gồm nhiều bước (như điền form, xác nhận).
2. **Bỏ qua bước bảo mật:** Họ bỏ qua các bước kiểm tra bảo mật và truy cập trực tiếp vào bước cuối.
3. **Khai thác:** Thực hiện hành động mà không cần hoàn thành các bước trước đó.

Ví dụ:

Một hệ thống cho phép người quản trị cập nhật thông tin người dùng qua ba bước: (1) Chọn người dùng, (2) Điền thông tin mới, (3) Xác nhận. Nếu chỉ có bước 1 và 2 có kiểm soát truy cập, kẻ tấn công có thể trực tiếp gửi yêu cầu HTTP đến bước 3 để xác nhận thay đổi mà không cần thông qua hai bước đầu tiên.

3.3. Dựa vào header Referer (Referer-based Access Control)

Một số trang web dựa vào header Referer trong yêu cầu HTTP để kiểm soát truy cập. Header Referer có thể được trình duyệt thêm vào các yêu cầu để chỉ ra trang nào đã khởi tạo yêu cầu.

Mục tiêu: Tấn công lợi dụng hệ thống kiểm soát truy cập dựa vào giá trị trong header *Referer*.

Các bước tấn công:

1. **Phân tích yêu cầu HTTP:** Kẻ tấn công kiểm tra và phát hiện hệ thống chỉ kiểm tra Referer để xác minh quyền truy cập.
2. **Giả mạo header Referer:** Họ tạo yêu cầu HTTP với header Referer giả mạo để đánh lừa hệ thống rằng yêu cầu đến từ một nguồn hợp lệ.
3. **Khai thác:** Thực hiện hành động trái phép.

Ví dụ:

Ví dụ, một ứng dụng có thể áp dụng kiểm soát truy cập chặt chẽ đối với trang chính quản trị tại /admin, nhưng đối với các trang phụ như /admin/deleteUser, chỉ kiểm tra header Referer. Nếu header Referer chứa URL chính /admin, yêu cầu sẽ được chấp nhận.



Trong trường hợp này, kẻ tấn công có thể hoàn toàn kiểm soát được header Referer. Điều này có nghĩa là họ có thể giả mạo các yêu cầu trực tiếp đến các trang phụ nhạy cảm bằng cách cung cấp header Referer phù hợp, và từ đó có quyền truy cập trái phép.

4. Một vài cách ngăn chặn việc phá vỡ kiểm soát truy cập

4.1. Áp dụng nguyên tắc ít quyền nhất (Principle of Least Privilege)

Nguyên tắc ít quyền nhất (PoLP) là một khái niệm an ninh mạng trong đó người dùng chỉ được cung cấp mức truy cập tối thiểu cần thiết để thực hiện các chức năng công việc của họ. Nguyên tắc này được áp dụng để ngăn chặn người dùng truy cập vào thông tin hoặc lệnh mà họ không cần cho công việc của mình, từ đó ngăn chặn họ gây hại cho hệ thống hoặc truy cập thông tin nhạy cảm.

Việc triển khai PoLP bắt đầu bằng việc xác định các vai trò khác nhau trong tổ chức và định nghĩa nhu cầu truy cập của từng vai trò. Mỗi vai trò chỉ nên có quyền truy cập vào các tài nguyên cần thiết để thực hiện nhiệm vụ công việc của mình—không hơn, không kém. Nguyên tắc này không chỉ áp dụng cho người dùng mà còn cho cả các quy trình, hệ thống, và thiết bị.

Tiếp theo, điều quan trọng là phải liên tục rà soát và cập nhật các vai trò này để phản ánh những thay đổi trong tổ chức. Khi nhân viên rời đi, gia nhập hoặc chuyển vị trí, nhu cầu truy cập của họ sẽ thay đổi. Việc thường xuyên rà soát các vai trò này đảm bảo rằng các quyền truy cập luôn phù hợp với nhu cầu hiện tại của từng vai trò.

4.2. Quản lý phiên và kiểm soát xác thực an toàn

Quản lý phiên an toàn và kiểm soát xác thực là một phần quan trọng khác để ngăn chặn việc phá vỡ kiểm soát truy cập. Các biện pháp này đảm bảo rằng chỉ những người dùng được ủy quyền mới có thể truy cập hệ thống của bạn và họ chỉ có thể truy cập những phần của hệ thống mà họ cần.

Quản lý phiên an toàn bao gồm việc tạo một phiên duy nhất cho mỗi người dùng khi họ đăng nhập và hủy phiên đó khi họ đăng xuất hoặc sau một khoảng thời gian không



hoạt động. Điều này ngăn chặn những người dùng không được ủy quyền chiếm đoạt phiên của người dùng khác và truy cập vào tài khoản của họ.

Các biện pháp xác thực xác minh rằng người dùng thực sự là người mà họ tuyên bố. Điều này thường được thực hiện thông qua sự kết hợp giữa tên người dùng và mật khẩu, nhưng cũng có thể bao gồm các phương pháp khác như sinh trắc học hoặc mã bảo mật.

Điều quan trọng là phải triển khai xác thực đa yếu tố (MFA), yêu cầu người dùng cung cấp hai hoặc nhiều yếu tố xác minh để có quyền truy cập. MFA giảm thiểu rủi ro kẻ tấn công truy cập vào hệ thống ngay cả khi họ có được mật khẩu của người dùng.

4.3. Kiểm tra và rà soát quyền truy cập định kỳ

Một phương pháp hay khác là thực hiện kiểm tra và rà soát quyền truy cập thường xuyên. Những cuộc kiểm tra này nên bao quát toàn bộ hệ thống kiểm soát truy cập của bạn, bao gồm cả vai trò và quyền truy cập được gán cho từng người dùng, cách cấp và thu hồi quyền truy cập, và các biện pháp an ninh để bảo vệ hệ thống kiểm soát truy cập.

Các cuộc kiểm tra định kỳ giúp đảm bảo rằng các chính sách kiểm soát truy cập của bạn đang được tuân thủ và không có bất kỳ lỗ hổng bảo mật nào có thể bị khai thác. Chúng cũng cung cấp cơ hội để xác định bất kỳ quyền truy cập dư thừa hoặc không cần thiết nào đã được cấp, cho phép bạn thu hồi những quyền này và giảm diện tấn công của hệ thống.

Ngoài ra, việc rà soát thường xuyên hệ thống kiểm soát truy cập của bạn có thể giúp bạn xác định bất kỳ xu hướng hoặc mô hình nào có thể chỉ ra một vấn đề bảo mật. Ví dụ: nếu một người dùng cụ thể liên tục cố gắng truy cập các tài nguyên mà họ không có quyền truy cập, điều này có thể cho thấy họ đang cố gắng khai thác một điểm yếu trong hệ thống kiểm soát truy cập của bạn.

4.4. Xử lý lỗi và ghi log đúng cách



Xử lý lỗi và ghi log đúng cách cũng là một khía cạnh quan trọng trong việc ngăn chặn việc phá vỡ kiểm soát truy cập. Các lỗi có thể cung cấp thông tin có giá trị về các lỗ hổng bảo mật tiềm ẩn trong hệ thống của bạn, và việc ghi lại các lỗi này có thể giúp bạn xác định và khắc phục những lỗ hổng này trước khi chúng bị khai thác.

Khi xảy ra lỗi, hệ thống của bạn nên ghi lại thông tin chi tiết về lỗi, bao gồm thời gian xảy ra, các hành động dẫn đến lỗi, và những tài nguyên bị ảnh hưởng. Tuy nhiên, bạn cũng cần cẩn trọng để đảm bảo rằng các thông tin nhạy cảm không được ghi lại trong log, vì điều này có thể vô tình tiết lộ các lỗ hổng bảo mật cho kẻ tấn công.

5. Tham khảo

<https://portswigger.net/web-security/access-control#horizontal-to-vertical-privilege-escalation>

<https://brightsec.com/blog/broken-access-control-attack-examples-and-4-defensive-measures/>

https://owasp.org/Top10/A01_2021-Broken_Access_Control/

Mọi thắc mắc hay ý kiến đóng góp vui lòng liên hệ :

Email : r3dctf.info@gmail.com

@Design by R3D CTF Team